

# Criptografía asimétrica integral

---

La clave pública habilita cifrado acotado, firmas y establecimiento de secretos, pero solo un protocolo autenticado y operado correctamente convierte esas primitivas en seguridad.

Material elaborado por el profesor Sergio Gevatschnaider

# Contenido

|                                                                         |           |
|-------------------------------------------------------------------------|-----------|
| <b>Propósito</b>                                                        | <b>3</b>  |
| <b>Resultados de aprendizaje</b>                                        | <b>3</b>  |
| <b>Núcleo teórico</b>                                                   | <b>3</b>  |
| <b>Profundización y criterio profesional</b>                            | <b>3</b>  |
| <b>1. Modelo funcional: cinco operaciones que no deben confundirse</b>  | <b>3</b>  |
| <b>2. Fundamentos matemáticos y supuestos de dificultad</b>             | <b>4</b>  |
| <b>3. RSA inspeccionable: del inverso modular a la operación segura</b> | <b>4</b>  |
| <b>4. Curvas elípticas sobre cuerpos finitos</b>                        | <b>5</b>  |
| <b>5. Firmas digitales: mensaje, contexto y unicidad</b>                | <b>5</b>  |
| <b>6. ECDH autenticado y resistencia a MITM</b>                         | <b>5</b>  |
| <b>7. Del secreto compartido a claves utilizables: HKDF</b>             | <b>6</b>  |
| <b>8. Arquitectura híbrida: establecimiento, derivación y AEAD</b>      | <b>6</b>  |
| <b>9. Claves efímeras, sesiones y secreto hacia adelante</b>            | <b>6</b>  |
| <b>10. PKI X.509 y validación de cadenas</b>                            | <b>7</b>  |
| <b>11. Ataques y fallos de ingeniería</b>                               | <b>7</b>  |
| <b>12. Ciclo de vida, custodia y agilidad</b>                           | <b>8</b>  |
| <b>13. Procedimiento de diseño y revisión</b>                           | <b>8</b>  |
| <b>14. Guía de lectura del laboratorio integral</b>                     | <b>8</b>  |
| <b>Caso de análisis</b>                                                 | <b>9</b>  |
| Entrega esperada . . . . .                                              | 9         |
| <b>Riesgos y errores frecuentes</b>                                     | <b>9</b>  |
| <b>Actividades de dominio</b>                                           | <b>9</b>  |
| <b>Lista de comprobación</b>                                            | <b>9</b>  |
| <b>Referencias seleccionadas</b>                                        | <b>9</b>  |
| <b>Rúbrica de dominio y evidencias</b>                                  | <b>10</b> |
| Recursos interactivos asociados . . . . .                               | 10        |

## Propósito

La clave pública habilita cifrado acotado, firmas y establecimiento de secretos, pero solo un protocolo autenticado y operado correctamente convierte esas primitivas en seguridad.

## Resultados de aprendizaje

1. explicar el par pública/privada y sus supuestos matemáticos.
2. distinguir cifrado, firma, acuerdo, KEM, KDF y AEAD.
3. reconstruir RSA y ECC con ejemplos inspeccionables.
4. analizar autenticación de claves públicas, PKI y cadenas de confianza.
5. diseñar una sesión híbrida con secreto hacia adelante.

## Núcleo teórico

Usa un par de claves pública y privada. Su costo hace que normalmente se utilice para:

- acuerdo de claves;
- encapsulación;
- firmas;
- autenticación;
- protección de claves de sesión.

No se utiliza normalmente para cifrar archivos completos.

## Profundización y criterio profesional

La publicación de una clave no demuestra a quién pertenece. Certificados, huellas verificadas, claves precompartidas, registros o firmas dentro de un protocolo establecen la vinculación de identidad. Sin ese paso, un acuerdo matemáticamente correcto puede sufrir MITM.

La asimétrica protege material pequeño, establece secretos o produce firmas. Los datos voluminosos se cifran con una clave simétrica de sesión. Esta arquitectura híbrida reduce costo, simplifica límites de tamaño y permite separar identidad, establecimiento y datos.

La validación incluye algoritmo, parámetros, uso autorizado, vigencia, revocación y formato. También debe contemplar canales laterales, errores uniformes y agilidad para migrar algoritmos.

## 1. Modelo funcional: cinco operaciones que no deben confundirse

La criptografía asimétrica no es una sola operación invertida. Un sistema moderno combina interfaces con objetivos diferentes. El cifrado de clave pública recibe una clave pública y un mensaje acotado; solo la privada correspondiente puede recuperar el mensaje. La firma recibe una clave privada y produce evidencia verificable con la pública. El acuerdo de clave recibe una clave privada local y una pública remota; ambos extremos calculan el mismo secreto, pero no lo transmiten. Un KEM encapsula un secreto y entrega un ciphertext de encapsulación. Una PKI distribuye afirmaciones firmadas sobre identidades y autorizaciones.

| Operación               | Entrada sensible                  | Salida principal | Propiedad                 | Riesgo si se usa aislada      |
|-------------------------|-----------------------------------|------------------|---------------------------|-------------------------------|
| RSA-OAEP                | Privada del receptor al descifrar | Mensaje acotado  | Confidencialidad          | Clave pública no autenticada  |
| RSA-PSS / ECDSA / EdDSA | Privada del firmante              | Firma            | Autenticidad e integridad | Contexto o identidad ambiguos |

| Operación     | Entrada sensible                      | Salida principal       | Propiedad                  | Riesgo si se usa aislada            |
|---------------|---------------------------------------|------------------------|----------------------------|-------------------------------------|
| ECDH / X25519 | Privada local                         | Secreto compartido     | Acuerdo                    | MITM sin autenticación              |
| KEM           | Privada del receptor al desencapsular | Secreto compartido     | Establecimiento            | Ciphertext o identidad sin vincular |
| Certificado   | Privada de la CA al emitir            | Credencial verificable | Vinculación y autorización | Validación parcial de la cadena     |

La clave privada debe quedar confinada al propósito autorizado. Publicar la clave pública permite verificación o establecimiento, pero no prueba quién la controla. La identidad se obtiene mediante una raíz de confianza, una huella verificada por otro canal, una clave precompartida o una firma validada dentro de un protocolo.

## 2. Fundamentos matemáticos y supuestos de dificultad

Un esquema asimétrico parte de una operación eficiente en la dirección legítima y de un problema que se considera difícil sin información secreta. En RSA, el módulo  $n$  es el producto de primos grandes. La seguridad no se resume en factorizar: depende del esquema de codificación, del tamaño, de la generación de primos, de la protección de operaciones privadas y de no filtrar errores. En ECC, los puntos forman un grupo; calcular  $Q = dG$  es eficiente, mientras recuperar  $d$  desde  $G$  y  $Q$  se relaciona con el logaritmo discreto elíptico.

El supuesto es una afirmación condicionada, no una prueba eterna. Debe registrarse junto con el nivel de seguridad, el horizonte de confidencialidad, la capacidad del adversario y la posibilidad de una computadora cuántica a gran escala. Shor afectaría de manera cualitativa a RSA, DH y ECC; por ello inventario, agilidad y migración poscuántica son partes del diseño.

No se comparan familias por la longitud visible de sus claves. Un módulo RSA, una clave EC y una clave AES expresan estructuras diferentes. Los bits de seguridad aproximan el costo del mejor ataque conocido contra la configuración completa. La selección debe seguir el perfil del protocolo y las normas aplicables, no una tabla aislada copiada sin contexto.

## 3. RSA inspeccionable: del inverso modular a la operación segura

El ejemplo educativo usa  $p = 61$ ,  $q = 53$  y  $e = 17$ . Entonces  $n = pq = 3233$  y  $\phi(n) = (p - 1)(q - 1) = 3120$ . Como  $\text{mcd}(17, 3120) = 1$ , existe  $d = e^{-1} \bmod \phi(n) = 2753$ . Para  $m = 65$ :

- Cifrado de libro:  $c = m^e \bmod n = 2790$ .
- Recuperación:  $m = c^d \bmod n = 65$ .
- Clave pública:  $(n, e)$ .
- Secreto esencial:  $d$  y los factores que permiten calcularlo.

Este vector solo demuestra la aritmética. Es inseguro porque el módulo se factoriza de inmediato, la operación es determinista y el mensaje carece de codificación resistente a ataques. En una implementación real, la exponenciación modular se realiza con algoritmos eficientes, la operación privada se protege frente a canales laterales y el descifrado no revela por sus errores qué parte de la codificación falló.

RSAs-OAEP aleatoriza y estructura el mensaje antes de la primitiva RSA. El límite de entrada para un módulo de  $k$  octetos y un hash de  $hLen$  octetos es  $k - 2hLen - 2$ . Con RSA 2048 y SHA-256,  $k = 256$  y  $hLen = 32$ , por lo que el máximo es 190 octetos. Este límite es una razón práctica para cifrar una clave aleatoria o usar un KEM, no archivos completos.

RSAs-PSS es una firma probabilística. La verificación reconstruye restricciones sobre el hash, la máscara y la sal. Cifrar con la privada no es una definición correcta de firma: omite codificación, dominio, formato y modelo de seguridad. OAEP y PSS tienen propósitos distintos aunque compartan la primitiva RSA.

## 4. Curvas elípticas sobre cuerpos finitos

Una curva corta de Weierstrass sobre un primo  $p$  puede escribirse como  $y^2 = x^3 + ax + b \pmod{p}$ , con discriminante no nulo. Los puntos que satisfacen la ecuación, junto con el punto al infinito, forman un grupo. La suma  $P + Q$  se define mediante pendientes modulares; duplicar  $P$  usa otra expresión para la pendiente. La multiplicación escalar  $dG$  repite sumas de forma eficiente mediante duplicar y sumar.

Para la curva didáctica  $y^2 = x^3 + 2x + 2 \pmod{17}$  y  $G = (5, 1)$ , se obtiene un grupo pequeño donde es posible enumerar puntos y seguir  $2G$ ,  $3G$  y sucesivos múltiplos. Esa transparencia permite verificar la ley de grupo, pero destruye la seguridad: el escalar privado se recupera enumerando posibilidades. Las curvas reales usan parámetros estandarizados y órdenes suficientemente grandes.

Una implementación debe validar la clave pública y sus parámetros antes de usarla. Importar bytes no convierte automáticamente una entrada hostil en un punto autorizado. Según el formato y el protocolo pueden ser necesarias validación de pertenencia, comprobación de orden, rechazo de valores especiales, formato canónico y confirmación de clave. Las bibliotecas de alto nivel deben concentrar estas reglas.

X25519 usa una interfaz de coordenada  $x$  sobre Curve25519 diseñada para acuerdo de clave y comportamiento robusto. P-256 ECDH y X25519 no comparten formato ni deben tratarse como nombres intercambiables. ECDSA y EdDSA son firmas; ECDH y X25519 son acuerdos. La semejanza de nombres no autoriza reutilizar claves entre propósitos.

## 5. Firmas digitales: mensaje, contexto y unicidad

Una firma protege una representación exacta del mensaje. Cambiar un bit, verificar con otra clave o interpretar los mismos bytes bajo otro contexto debe provocar rechazo. La aplicación debe definir qué se firma: versión, tipo de objeto, identificador de protocolo, identidad esperada, algoritmo, clave efímera y datos relevantes. Firmar solo un campo visible puede permitir sustitución o reinterpretación.

ECDSA calcula una firma  $(r, s)$  a partir del hash del mensaje, la clave privada  $d$  y un secreto por mensaje  $k$ . Reutilizar  $k$  en dos firmas o generarlo de forma predecible puede revelar  $d$ . Una biblioteca vigente debe encargarse de la generación determinista o aleatoria conforme al perfil elegido. EdDSA emplea otra construcción y reglas de codificación; no es simplemente ECDSA sobre una curva Edwards.

RSA-PSS, ECDSA y EdDSA permiten verificación pública, pero una verificación válida solo demuestra que la clave correspondiente produjo la firma sobre esos bytes. Para atribuir la acción a una persona, servicio o rol se necesitan políticas de identidad, protección de la clave, registro, autorizaciones, marca temporal cuando corresponda y tratamiento de compromiso o revocación.

| Verificación          | Pregunta respondida                            | Pregunta todavía abierta                      |
|-----------------------|------------------------------------------------|-----------------------------------------------|
| Firma matemática      | ¿Coinciden mensaje, firma y clave?             | ¿A quién pertenece la clave?                  |
| Certificado válido    | ¿Una cadena autorizada vinculó nombre y clave? | ¿La política acepta esa raíz y uso?           |
| Registro de auditoría | ¿Cuándo y dónde se observó la operación?       | ¿El dispositivo estaba bajo control legítimo? |

## 6. ECDH autenticado y resistencia a MITM

Alice genera  $a$  y publica  $A = aG$ . Bob genera  $b$  y publica  $B = bG$ . Alice calcula  $aB = abG$  y Bob calcula  $bA = abG$ . Un observador no debería recuperar  $abG$  a partir de  $G$ ,  $A$  y  $B$  bajo el supuesto del logaritmo discreto. Sin embargo, Mallory puede reemplazar  $A$  y  $B$ , establecer un secreto con cada extremo y retransmitir datos. El acuerdo funcionará, pero con la contraparte equivocada.

La defensa vincula la clave efímera con una identidad y con la transcripción. Por ejemplo, Bob firma una estructura canónica que contiene versión, suite, roles, contexto de aplicación, identificador de sesión y su clave efímera. Alice valida la credencial de Bob, verifica la firma y solo entonces deriva claves. Si Mallory cambia la clave, la firma deja de validar. Si copia la firma a otro protocolo o rol, el contexto incluido evita la reutilización.

Autenticar una sola clave no basta si la transcripción permite downgrade o confusión de algoritmos. La suite negociada, los parámetros y las contribuciones deben quedar incluidos directa o indirectamente en el transcript hash. La confirmación explícita de clave demuestra que ambos extremos derivaron el mismo material y vieron la misma sesión.

## 7. Del secreto compartido a claves utilizables: HKDF

El resultado bruto de ECDH no debe usarse directamente como clave para todas las funciones. HKDF separa extracción y expansión. Extract recibe salt e input keying material y produce una pseudorandom key. Expand combina esa clave con información de contexto para obtener tantos octetos como requiere cada propósito.

Un diseño puede derivar claves distintas con etiquetas inequívocas:

- modulo03/v1/alice-a-bob/aead-key
- modulo03/v1/bob-a-alice/aead-key
- modulo03/v1/alice-a-bob/nonce-base
- modulo03/v1/exporter

La etiqueta evita que el mismo secreto se interprete como clave de cifrado, MAC, exportador o tráfico en ambas direcciones. El salt no reemplaza la entropía del secreto y la información de contexto no necesita ser secreta. Debe ser estable, canónica y conocida por ambos extremos. Las claves derivadas deben limitarse a los usos necesarios y eliminarse cuando termina la sesión.

## 8. Arquitectura híbrida: establecimiento, derivación y AEAD

Los datos voluminosos se protegen con AEAD porque el cifrado simétrico es eficiente y puede autenticar ciphertext y metadatos. El flujo completo es:

1. Validar identidad y parámetros de la contraparte.
2. Ejecutar acuerdo o desencapsulación.
3. Derivar claves y nonces con una KDF contextual.
4. Cifrar cada registro con AES-GCM o ChaCha20-Poly1305.
5. Autenticar como AAD versión, dirección, contador y encabezados relevantes.
6. Rechazar el registro completo si el tag falla.
7. Rotar y destruir claves según límites de sesión.

HPKE formaliza combinaciones de KEM, KDF y AEAD para cifrado híbrido de clave pública. Sus modos base y autenticados tienen garantías diferentes. Elegir una suite HPKE no reemplaza la autenticación de aplicación cuando el modo seleccionado no aporta la identidad requerida. Tampoco reemplaza la protección frente a replay, el orden de mensajes o la semántica de autorización.

Un paquete educativo puede contener suite, clave encapsulada o pública efímera, salt, nonce, AAD, ciphertext y tag. El paquete real debe usar un formato canónico, longitudes verificadas y selección de algoritmo no ambigua. Nunca debe aceptar parámetros suministrados por el atacante sin comprobar que pertenecen al perfil permitido.

## 9. Claves efímeras, sesiones y secreto hacia adelante

El secreto hacia adelante busca que el compromiso futuro de una clave de identidad de largo plazo no revele automáticamente sesiones pasadas. Una construcción típica usa ECDH efímero autenticado: las claves de identidad firman la transcripción, mientras los escalares efímeros producen el secreto de sesión y luego se eliminan.

No alcanza con llamar "de sesión" a una clave. Si una clave simétrica fue transportada bajo RSA estático y un atacante guardó el ciphertext, el compromiso posterior de la privada RSA puede permitir recuperar esa sesión. Tampoco hay secreto hacia adelante si los escalares efímeros se registran, respaldan o reutilizan. La propiedad depende de protocolo, autenticación, generación fresca, eliminación y horizonte de compromiso.

La reanudación de sesiones introduce nuevos secretos y tickets. Debe analizarse si hereda, renueva o reduce la propiedad. Los contadores, límites de registros y políticas de rekey evitan usar una clave más allá de los márgenes del AEAD. El diseño debe poder identificar qué clave protegió cada registro sin publicar secretos.

## 10. PKI X.509 y validación de cadenas

Un certificado vincula una clave pública con un sujeto y restricciones mediante la firma de un emisor. Una cadena típica contiene una entidad final, una o más CA intermedias y una raíz que el verificador ya confía por configuración local. La raíz no se vuelve confiable porque se autofirme; la autofirma prueba consistencia, mientras la confianza proviene del almacén y de la política.

Validar una cadena requiere más que verificar firmas:

- construir una ruta hasta un ancla aceptada;
- verificar firmas y codificaciones;
- comprobar vigencia en el instante pertinente;
- aplicar Basic Constraints y límites de longitud;
- aplicar Key Usage y Extended Key Usage;
- verificar el nombre o identidad esperada;
- procesar políticas y restricciones de nombre cuando correspondan;
- considerar revocación o mecanismos equivalentes según el entorno;
- rechazar algoritmos, tamaños y parámetros fuera de política.

La simulación del módulo usa objetos JSON firmados para hacer visible esta lógica, pero no pretende analizar DER, ASN.1 ni certificados X.509. La diferencia se declara porque una demostración de firmas encadenadas no cubre todas las reglas de RFC 5280.

## 11. Ataques y fallos de ingeniería

| Fallo                               | Consecuencia                         | Control principal                            |
|-------------------------------------|--------------------------------------|----------------------------------------------|
| Clave pública sin autenticar        | MITM                                 | Firma, certificado, huella o PSK verificada  |
| RSA sin OAEP/PSS                    | Determinismo, maleabilidad o forgery | Esquema estandarizado y biblioteca mantenida |
| Nonce ECDSA repetido                | Recuperación de privada              | Generación conforme a estándar               |
| Punto o clave no validada           | Subgrupos, resultados inválidos      | Importación y validación estrictas           |
| Error de descifrado distinguible    | Oráculo adaptativo                   | Errores uniformes y protocolo CCA-seguro     |
| Clave para varios propósitos        | Ataques cruzados                     | Separación por KDF y política                |
| Efímeras conservadas                | Pérdida de secreto hacia adelante    | Eliminación y no registro                    |
| Cadena validada parcialmente        | Suplantación                         | Validador completo y política explícita      |
| Algoritmo negociable sin transcript | Downgrade                            | Autenticar negociación y versión             |
| Operación variable en tiempo        | Canal lateral                        | Implementación resistente y aislamiento      |

Los mensajes de error deben ser útiles para operación sin convertirse en señales criptográficas. Internamente se registra una categoría segura; externamente se evita revelar si falló padding, clave, formato o tag. Los límites de

tamaño y tiempo se aplican antes de operaciones costosas para reducir denegación de servicio.

## 12. Ciclo de vida, custodia y agilidad

La clave privada de identidad suele requerir mayor protección y vida más larga que una clave efímera. Puede residir en un HSM, TPM, enclave o almacén de claves del sistema. Exportabilidad, respaldo, recuperación, rotación y destrucción deben responder a la función. Una clave de firma de CA requiere controles diferentes de una clave ECDH efímera de navegador.

El inventario debe registrar algoritmo, parámetros, biblioteca, propietario, ubicación, propósito, dependencias, fecha de expiración y datos protegidos. La agilidad no significa aceptar cualquier algoritmo anunciado: significa poder migrar dentro de una lista controlada, con negociación autenticada, telemetría y retirada verificable.

La transición poscuántica exige localizar dónde se usan RSA, DH y ECC, cuánto tiempo deben permanecer secretos los datos y qué interfaces soportan reemplazo o esquemas híbridos. FIPS 203 estandariza ML-KEM para establecimiento poscuántico, pero su integración requiere perfiles, bibliotecas y protocolos concretos. Una migración híbrida combina supuestos solo si el combiner y el protocolo preservan las propiedades esperadas.

NIST publicó SP 800-56A Rev. 3 en 2018 y anunció en enero de 2026 que la actualizará, entre otros objetivos, para alinear requisitos de curvas y contemplar implementaciones de coordenada x. Por eso el material distingue principios estables de perfiles que deben revisarse al implementar.

## 13. Procedimiento de diseño y revisión

1. Definir activos, propiedad, adversario y duración.
2. Elegir si se necesita cifrado, firma, acuerdo, KEM o varias funciones.
3. Seleccionar un protocolo y perfil interoperable, no primitivas sueltas.
4. Definir raíz de confianza y proceso de enrolamiento.
5. Autenticar negociación, roles, claves efímeras y transcript.
6. Derivar subclaves con contexto y separación de direcciones.
7. Proteger registros con AEAD y política de nonce.
8. Especificar errores, replay, rekey, límites y eliminación.
9. Usar vectores conocidos, pruebas negativas y revisión de interoperabilidad.
10. Inventariar dependencias y planificar migración.

La evidencia mínima incluye pruebas de OAEP y PSS, firmas válidas e inválidas, acuerdo coincidente, rechazo de una clave efímera sustituida, derivación contextual, rechazo de ciphertext o AAD alterados, cadena válida, cadena modificada y raíz incorrecta. La prueba positiva demuestra funcionamiento; las negativas demuestran que el sistema falla de manera segura.

## 14. Guía de lectura del laboratorio integral

El experimento RSA separa pares OAEP y PSS, muestra huellas y permite alterar entrada. El experimento ECDSA compara mensaje original, mensaje alterado y clave equivocada. El experimento ECDH firma la pública efímera de Bob, verifica el contexto, deriva con HKDF y protege el mensaje con AES-GCM. Las acciones MITM y alteración evidencian qué control produce el rechazo.

X25519 se ejecuta cuando el motor Web Crypto lo ofrece y muestra hashes truncados del secreto solo para comprobar igualdad sin exponerlo como una clave reutilizable. La cadena educativa genera raíz, intermedia y entidad final, firma estructuras canónicas y comprueba emisor, vigencia, restricciones y firmas. No reemplaza un validador X.509.

Cada ejecución usa claves nuevas y datos ficticios en memoria local. Recargar descarta el estado. El objetivo es observar contratos criptográficos, no producir material para un sistema real.

## Caso de análisis

Analice una aplicación que descarga una clave pública desde el mismo canal no autenticado que intenta proteger. Modele MITM y proponga dos raíces de confianza.

## Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

## Riesgos y errores frecuentes

- cifrar archivos completos con RSA.
- suponer que pública significa auténtica.
- usar la misma clave para cifrado y firma sin política.
- usar el secreto ECDH directamente sin KDF ni contexto.
- verificar firmas de certificados sin validar nombre, vigencia, usos y ancla.
- atribuir secreto hacia adelante a cualquier clave de sesión.

## Actividades de dominio

1. ¿Qué resuelve y qué no resuelve una clave pública?
2. ¿Por qué se usa cifrado híbrido?
3. ¿Qué diferencia OAEP de PSS?
4. ¿Cómo evita una firma contextual la sustitución de una clave ECDH efímera?
5. ¿Qué verifica una cadena y de dónde proviene la confianza de la raíz?
6. ¿Qué condiciones hacen posible el secreto hacia adelante?

## Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

## Referencias seleccionadas

1. RFC 8017: PKCS #1 v2.2 - <https://www.rfc-editor.org/rfc/rfc8017>
2. FIPS 186-5: Digital Signature Standard - <https://doi.org/10.6028/NIST.FIPS.186-5>
3. NIST SP 800-56A Rev. 3: Key Establishment - <https://doi.org/10.6028/NIST.SP.800-56Ar3>
4. NIST SP 800-186: Elliptic Curve Domain Parameters - <https://doi.org/10.6028/NIST.SP.800-186>
5. RFC 7748: Elliptic Curves for Security - <https://www.rfc-editor.org/rfc/rfc7748>
6. RFC 8032: EdDSA - <https://www.rfc-editor.org/rfc/rfc8032>

7. RFC 5280: Internet X.509 PKI Certificate Profile - <https://www.rfc-editor.org/rfc/rfc5280>
8. RFC 5869: HKDF - <https://www.rfc-editor.org/rfc/rfc5869>
9. RFC 9180: Hybrid Public Key Encryption - <https://www.rfc-editor.org/rfc/rfc9180>
10. RFC 8446: TLS 1.3 - <https://www.rfc-editor.org/rfc/rfc8446>
11. FIPS 203: Module-Lattice-Based KEM - <https://doi.org/10.6028/NIST.FIPS.203>
12. NIST SP 800-57 Part 1 Rev. 5: Key Management - <https://doi.org/10.6028/NIST.SP.800-57pt1r5>
13. NIST SP 800-131A Rev. 2: Algorithm Transitions - <https://doi.org/10.6028/NIST.SP.800-131Ar2>
14. RFC 6979: Deterministic DSA and ECDSA - <https://www.rfc-editor.org/rfc/rfc6979>
15. RFC 6960: Online Certificate Status Protocol - <https://www.rfc-editor.org/rfc/rfc6960>
16. RFC 8555: Automatic Certificate Management Environment - <https://www.rfc-editor.org/rfc/rfc8555>
17. RFC 9162: Certificate Transparency Version 2.0 - <https://www.rfc-editor.org/rfc/rfc9162>
18. NIST planning note, January 2026: update of SP 800-56A - <https://csrc.nist.gov/news/2026/nist-to-revise-key-establishment-recommendations>

## Rúbrica de dominio y evidencias

| Dimensión     | Dominio observable                                      | Evidencia insuficiente                            |
|---------------|---------------------------------------------------------|---------------------------------------------------|
| Propiedades   | Separa cifrado, firma, acuerdo, KEM, KDF y AEAD         | Llama cifrado a toda operación                    |
| Matemática    | Reconstruye RSA pequeño y explica la ley de grupo EC    | Copia resultados sin justificar inversos o puntos |
| Autenticación | Vincula identidad, efímera, roles, suite y transcript   | Confía en una pública por haberla recibido        |
| Sesión        | Deriva subclaves contextuales y autentica registros     | Usa directamente el secreto ECDH                  |
| PKI           | Valida ruta, firma, nombre, vigencia, usos y ancla      | Comprueba únicamente una firma                    |
| Operación     | Define custodia, rotación, errores, borrado y migración | Trata el algoritmo como único control             |

La demostración debe incluir pruebas negativas. Se espera rechazo al cambiar un mensaje firmado, usar otra clave pública, sustituir una efímera, modificar el contexto, alterar un ciphertext, presentar una cadena modificada o cambiar el ancla de confianza. Un resultado positivo muestra que el mecanismo funciona; un rechazo controlado muestra que falla de manera segura.

## Recursos interactivos asociados

- [simuladores/modulo-03/asimetria-teoria-completa.html](#): modelo RSA y curva finita inspeccionables, doce secciones y glosario.
- [simuladores/modulo-03/asimetria-laboratorio-integral.html](#): RSA-OAEP/PSS, ECDSA, ECDH autenticado, X25519 y cadena firmada.
- [simuladores/modulo-03/ruta-clase-asimetria.html](#): recorrido de 100 minutos, progreso local y evaluación de salida.
- [simuladores/modulo-03/rsa-ecdh-hibrido.html](#): laboratorio aplicado anterior preservado para comparación.
- [simuladores/modulo-03/cifrado-hibrido-sesion.html](#): arquitectura conceptual RSA, ECC, HPKE, HKDF y AEAD.